

Internal Data and Incident Procedures

Deaf Shark Coffee | Retention and deletion procedure followed by breach response plan

Effective only after owner approval. Automatic deletion remains disabled until the accountant and New Jersey counsel confirm the financial, employment, insurance, and dispute-retention periods.

1 Purpose and owner

This procedure limits personal information to what Deaf Shark Coffee needs for service, security, legal, accounting, employment, and dispute purposes. The business owner is accountable for the schedule. A named technical administrator performs approved exports, anonymization, and deletion and records each run. No staff member may delete records informally.

2 Approved working schedule

- Active account and profile: retain while active. After authenticated closure, delete the profile and authentication records, forfeit loyalty benefits, and anonymize the account link, customer name, phone number, and text consent in retained orders.
- Orders, refunds, taxes, and financial summaries: retain minimum transaction records for seven years unless the accountant approves a different period. Remove direct customer identifiers earlier when operationally feasible.
- Loyalty, referral, student, birthday, and member-offer data: delete on verified account closure, normally within 30 days, unless a specific fraud or dispute hold applies.
- Contact inquiries: retain for up to two years after the matter closes, then delete or anonymize.
- Unsuccessful job applications and resumes: retain for two years, then securely delete. Records for hired applicants move to the personnel-record schedule.
- Marketing consent: retain while subscribed. After opt-out or closure, retain only a minimal suppression record needed to prevent future marketing.
- Expired sessions and verification tokens: delete within 90 days after expiration.
- Security and access logs: retain up to 12 months unless an active incident, fraud review, insurer request, or legal hold requires longer.
- Backups: use a documented rolling window of 35 to 90 days and allow deleted data to age out through normal rotation.

3 Account closure

The customer must be authenticated and type DELETE to confirm closure. The system revokes sessions, removes authentication and profile records, deletes loyalty and offer records, changes marketing to unsubscribed, and anonymizes retained order records. It does not erase transaction amounts, taxes, ordered items, status, or dates needed for accounting, refunds, fraud review, or disputes. Contact-form and employment records are evaluated under their own schedules because they may have been submitted for a separate purpose.

4 Information downloads and manual requests

An authenticated customer may download a JSON copy from account settings. Requests received at help@deafsharkcoffee.com must be logged with the date, identity-verification method, scope, decision, response date, and any exception. Never send password hashes, session tokens, authentication tokens, internal security signals, or another person's information. Escalate uncertain requests to counsel.

5 Quarterly review process

- Export a count by record category and age without exposing record contents unnecessarily.
- Check for records past the approved period and for deletion jobs that failed.
- Confirm that legal, insurer, chargeback, tax, employment, and incident holds are documented before deletion.
- Run approved deletion or anonymization against a backup-tested procedure, then record counts and completion time.
- Review staff access, remove departed personnel, and verify every administrator uses an individual account with multifactor authentication.
- Review vendors, policy versions, marketing tools, pixels, and new data fields for schedule changes.

6 Legal holds and exceptions

Suspend normal deletion only for a documented reason such as a subpoena, threatened claim, active chargeback, tax examination, employment matter, security incident, or insurer instruction. Record the affected category, approving person, start date, and review date. Release the hold promptly when the reason ends and resume normal disposition.

7 Annual approval

The owner reviews this procedure at least annually and whenever payment, marketing, text messaging, employment, analytics, gift-card, or ordering practices change. The accountant confirms financial periods; counsel confirms legal exceptions; and the technical administrator confirms that the live database, backups, logs, and vendor systems match the approved schedule.

Data Breach Response Plan

Deaf Shark Coffee | Internal procedure | Version 1.0

Keep an offline copy of this plan. It is an operational checklist, not a substitute for breach counsel, insurer instructions, law-enforcement direction, or vendor incident procedures.

1 Report and activate

Anyone who notices a lost device, exposed credential, suspicious login, malware, misdirected customer data, unauthorized database access, vendor alert, or accidental public file must immediately notify the owner and technical administrator. Do not investigate through personal accounts or discuss the incident publicly. Record who reported it, when it was discovered, affected systems, and known facts without guessing.

2 First-hour containment

- Preserve evidence: screenshots, audit logs, emails, timestamps, affected URLs, account identifiers, and vendor ticket numbers. Do not erase logs or rebuild affected systems before evidence is saved.
- Contain access: disable compromised accounts, revoke sessions and API keys, rotate affected secrets, isolate exposed systems, and restrict database access. Do not destroy the only evidence copy.
- Protect operations: pause affected checkout, account, messaging, or application features if continued operation could increase harm.
- Contact the cyber insurer before hiring outside vendors or making admissions if the policy requires prior approval.
- Open urgent tickets with Cloudflare, Stripe, Google, Twilio, email, hosting, or other affected providers and preserve their responses.

3 Assess scope and risk

Create a verified inventory of what happened, the access window, systems and vendors involved, individuals and jurisdictions affected, data elements exposed, whether data was encrypted, evidence of acquisition or misuse, restoration status, and continuing risks. Separate confirmed facts from assumptions. Preserve a decision log and chain of custody for exported evidence.

4 Legal and regulatory review

Promptly involve qualified breach counsel when personal information may have been accessed or acquired without authorization. Counsel should determine whether notification duties apply, deadlines, content, substitute notice, consumer reporting obligations, contractual notices, and law-enforcement coordination. For a qualifying New Jersey breach, follow current New Jersey requirements, including notifying the New Jersey State Police Cyber Crimes Unit before notifying affected New Jersey customers when required. Do not delay a required notice for marketing or reputation reasons.

5 Customer and partner communications

Use one approved factual message that states what happened, the dates, information involved, actions taken, steps customers can take, and a reliable contact method. Do not speculate, minimize, promise that no harm can occur, or include sensitive data in the notice. Coordinate notices to affected vendors, payment partners, insurers, banks, regulators, and law enforcement as counsel directs. Maintain copies and delivery records.

6 Recovery

- Verify the vulnerability is closed before restoring affected functions.
- Restore from known-good backups and validate permissions, logging, rate limits, multifactor authentication, and secret rotation.
- Monitor for repeat access, fraud, chargebacks, credential attacks, and suspicious account changes.
- Provide staff with narrowly tailored instructions and a single contact for customer questions.
- Document systems restored, tests performed, unresolved risks, and the owner who approved return to service.

7 Post-incident review

Within 14 days after containment, document root cause, impact, response times, decisions, notices, costs, evidence location, and corrective actions with owners and deadlines. Update access controls, retention, vendor settings, training, policies, and this plan. Preserve the incident file for the period approved by counsel and the insurer. Conduct a tabletop exercise at least annually.

8 Contact sheet to complete before launch

- Business owner and after-hours number.
- Technical administrator and backup contact.
- Cyber insurer policy number and incident hotline.
- New Jersey breach/privacy counsel.
- Cloudflare, Stripe, Google, Twilio, email provider, bank, and POS support contacts.
- New Jersey State Police Cyber Crimes Unit current reporting channel, verified from nj.gov at the time of an incident.